RSI GROUP · HIVE PROJECT 2027

RSI Group · 邊界 WAAP 在線防護 & 旁路 API 安全態勢雙軌聯防架構

去品牌化通用技術標準 · 雙向動態閉環阻斷 · 相關角色技術職能問卷題本

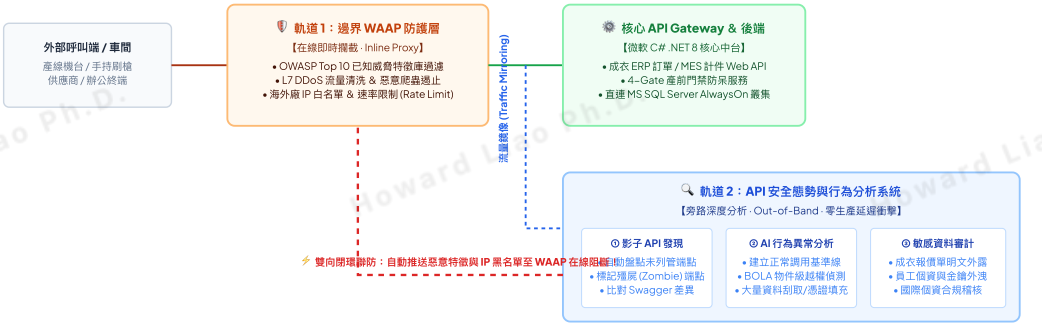
專案指導：**周文津 副總經理**
架構規劃：**Howard Liao Ph.D. 外部顧問**
FORM SUITE: RSI-SIMULTANEOUS-ROLES-2027

📌 **核心架構定位與非取代原則 (Architectural Separation of Concerns)：**
1. **不是強行合併，亦非互相取代**：邊界 WAAP (Web 應用程式與 API 防護) 專注於**入口處毫秒級在線攔截（Inline Blocking）**；API 安全系統專注於**旁路深度語意分析、影子資產發現與業務邏輯漏洞識別（Out-of-Band Behavioral & Posture Analysis）**。
2. **動態回饋閉環聯防 (Closed-Loop Remediation)**：當旁路 API 安全系統透過流量鏡像偵測到 BOLA 越權攻擊、帳號爬取異常或高風險未授權行為時，自動透過 Webhook/API 將威脅特徵與惡意 IP 即時反饋推送到邊界 WAAP 實現在線阻斷！
3. **零生產延遲衝擊**：旁路採用 Traffic Mirroring 拷貝流量進行 AI 基準線學習，完全不拖慢成衣車間工單計件與 4-Gate 產前門禁的響應速度。

🖨️ 列印圖資 (強制每頁浮水印)

🏛️ 第一部分：邊界 WAAP + 旁路 API 安全雙軌聯防拓撲圖 Closed-Loop Bidirectional Defense

【雙軌架構拓撲】邊界在線防護 + 旁路行為分析 + 自動閉環回饋阻斷



💡 **架構設計深意：**

1. 邊界 WAAP 只能阻擋已知特徵攻擊（如 SQLi），完全看不懂合法的 API 呼叫是否在越權偷看他人成衣報價（BOLA）。
2. 旁路 API 安全系統深度理解語意與業務行為，當它抓到越權行為時，自動回傳封鎖指令給 WAAP，形成完美的閉環安全！

Howard Liao Ph.D.

📋 第二部分：WAAP + API 安全相關核心角色問卷題庫 (共 4 大關鍵角色)

已同步更新至全站評鑑系統

落實此雙軌安全體系，牽涉資安、後端開發、SRE 維運與專案主管 4 大角色。以下為各角色專屬檢核考題：

🛡️ 【核心角色 1】[R09-SEC] 資訊安全工程師 (Cybersecurity, WAAP & API Security)

題號代碼	實務題目名稱	實務情境檢核標準 (Checklist)
[R09-SEC-01]	邊界 WAAP 在線規則配置與 DDoS 流量過濾	能否熟練維護邊界 WAAP/WAF 在線代理規則，配置 OWASP Top 10 防護特徵庫、速率限制 (Rate Limiting) 與成衣海外廠 IP 白名單，在入口端毫秒級阻擋惡意攻擊？
[R09-SEC-02]	旁路 API 影子資產與殭屍端點自動發現	能否透過流量鏡像 (Traffic Mirroring) 部署旁路 API 安全系統，動態比對 Swagger 契約與真實流量，秒級盤點出未納管的影子 API (Shadow APIs) 與廢棄殭屍端點？
[R09-SEC-03]	API 運行時基準線學習與 AI 行為異常偵測	能否利用 API 安全引擎建立每支業務 API 的正常調用基準線 (Baseline)，精準辨識資料異常抓取 (Scraping)、帳號憑證填充與非常規時段的大量讀取行為？
[R09-SEC-04]	物件級越權 (BOLA) 與業務邏輯漏洞專項防禦	當合法登入之攻擊者透過替換工單 ID 或工序代碼存取其他車間資料時，能否透過 API 語義與參數脈絡分析即時識別此類傳統 WAF 無法防範的 BOLA 業務邏輯越權？
[R09-SEC-05]	邊界 WAAP 阻斷與旁路 API 安全雙向動態聯防閉環機制	是否深刻理解「邊界 WAAP 負責在線阻擋、旁路 API 安全負責深度洞察，兩者非互相取代亦非強行合併」之原則，並能配置 API 安全偵測威脅後自動推送動態規則至邊界 WAAP 即時阻斷？
[R09-SEC-06]	API 負載敏感資料外洩防護 (DLP 內容審計)	能否深入檢查 API Request / Response 負載內容，自動稽核成衣報價單、工序計件工資、客戶合約與身分憑證是否以明文外露，並觸發資安預警？

💻 【核心角色 2】[R02-BE] 後端軟體開發工程師 (Backend .NET Developer)

題號代碼	實務題目名稱	實務情境檢核標準 (Checklist)
[R02-BE-02]	RESTful API 規格設計與 Swagger 規格防影子端點	能否嚴格遵守契約優先 (Contract-First)，後端改動即時更新 Swagger 文件，主動通報資安團隊消除影子 API (Shadow API) 盲點？
[R02-BE-04]	資料庫交易事務控制與物件級存取權限校驗 (BOLA 防護)	在 C# 控制器中，能否在查詢資料前嚴格校驗當前使用者的工廠代碼與廠長身分，杜絕單純依賴前端傳入 ID 造成的 BOLA 水平越權漏洞？
[R02-BE-10]	API 敏感欄位遮蔽 (Masking) 與回傳最小化	能否使用 DTO 嚴格過濾後端回傳欄位，避免將未經處理的資料庫整表實體 (Entity) 直接序列化回傳，防止機密成衣單價與成本洩漏？

🛠️ 【核心角色 3】[R10-SRE] 網站可靠性 / DevOps 工程師 (SRE & DevOps)

題號代碼	實務題目名稱	實務情境檢核標準 (Checklist)
[R10-SRE-03]	流量鏡像 (Traffic Mirroring) 旁路拋送配置	能否在負載平衡器或反向代理配置異步流量複製 (Mirroring)，將即時請求副本無感推送至 API 安全分析叢集，保證生產環境零延遲？
[R10-SRE-07]	CI/CD 靜態 API 契約安全掃描自動化門禁	能否在 GitHub Actions / Azure DevOps Pipeline 整合 API 規格掃描，在代碼合併前自動攔截未經身分驗證的高風險開放 API？

👔 【核心角色 4】[R13-PM] 資訊主管 / 專案經理 (Lead & Project Manager)

題號代碼	實務題目名稱	實務情境檢核標準 (Checklist)
[R13-PM-06]	全集團 API 資產台帳治理與影子端點清零 KPI	能否建立全集團跨廠 API 資產登記制度，定期審查影子 API 發現清單，要求各廠資訊團隊限期完成合規納管或下線？

題號代碼	實務題目名稱	實務情境檢核標準 (Checklist)
[R13-PM-08]	邊界在線防護與旁路安全之雙軌預算審查	能否清晰向經營階層論證「邊界 WAAP 阻斷」與「旁路 API 安全態勢」兩者分工之必要性，精準評估 TCO 投資回報率？

Howard Liao Ph.D.

⚖️ 第三部分：邊界 WAAP vs 旁路 API 安全技術職能本質深度對照表

比較維度	邊界 WAAP 防護 (在線串聯 · Inline)	API 安全態勢與行為分析 (旁路分析 · Out-of-Band)
部署位置與拓撲	位於網路最前端，流量必須經過其反向代理 (Inline Proxy)。	透過流量鏡像 (Traffic Mirroring) 或 eBPF 探針旁路接收副本，完全不介入主鏈路。
對生產交易之延遲	增加 1~5ms 檢查耗時。	**0ms（完全零延遲衝擊）**。
影子 API (Shadow) 發現	❌ **無法發現**（只能保護設定在它後面的已列管站台）。	✅ **核心強項**（自動分析全流量，秒級抓出未列管的開發端點與殭屍 API）。
業務邏輯漏洞 (BOLA)	❌ **極難防範**（合法請求格式無法觸發特徵阻斷）。	✅ **核心強項**（透過上下文與行為基準線，精準抓出水平越權與異常刮取）。
阻斷動作與響應	✅ **在線即時攔截**（直接回傳 403 Forbidden 掐斷連線）。	⚠️ 旁路分析不直接阻斷，而是**將特徵動態反饋推送給 WAAP 執行在線阻斷**。
防護目標與盲點	防範已知特徵攻擊、DDoS 與惡意 Bot；盲點在於不理解業務語義。	防範未知邏輯漏洞、帳號濫用與影子資產；需搭配 WAAP 實現入口閉環。
信源架構結論	**兩者是「護門盾牌 (WAAP)」與「深層透視眼 (API Security)」的黃金搭檔，絕不可強行合併或相互取代！**	

Howard Liao Ph.D.